

WAF on AWS: The Basics and 3 Critical Best Practices

What Is AWS WAF?

AWS WAF is a web application firewall that monitors HTTP(S) requests directed to Amazon CloudFront distributions, Amazon API Gateway REST APIs, Application Load Balancers, or AWS AppSync GraphQL APIs.

AWS WAF can also control access to web content. You can limit access based on criteria including:

- IP address
- Query string
- Rules using combinations of the above

A service associated with a protected resource either provides the requested resources, if allowed by the WAF, or returns HTTP 403 (Forbidden) status code if disallowed by the WAF. You can also configure CloudFront to return a custom error page when a request is blocked.

AWS WAF is part of a set of [cloud security](#) services provided by Amazon, which also includes AWS Firewall Manager and AWS Shield, Amazon's distributed denial of service (DDoS) mitigation solution.

What Are AWS Firewall Manager and AWS Shield?

AWS WAF, AWS Firewall Manager, and AWS Shield together to secure web applications deployed on AWS.

AWS WAF on its own gives you fine-grained control over protection of web resources. Combining AWS WAF with Firewall Manager lets you use the WAF between AWS accounts and automate AWS WAF configuration.

Combining AWS with WAF lets you protect your web applications against distributed denial of service (DDoS) attacks.

AWS Firewall Manager

Firewall Manager simplifies the management and maintenance of multiple accounts and resources for a variety of protections, including AWS WAF, AWS Shield Advanced, Amazon VPC Security Groups, AWS Network Firewall, and Amazon Route 53 Resolver DNS Firewall.

With Firewall Manager, you set up protection once and the service automatically applies protection to an entire AWS account and all its resources, including new resources added after protection was set up, and the ability to support multiple AWS accounts.

AWS Shield

You can use AWS WAF web access control lists (ACLs) to minimize the impact of distributed denial of service (DDoS) attacks. AWS Shield comes in two editions:

- **AWS Shield Standard** is included with AWS accounts automatically at no additional cost.
- **AWS Shield Advanced** is provided at additional charge. It offers extended DDoS attack protection for Amazon EC2 instances, Elastic Load Balancing load balancers, CloudFront distributions, Route 53 hosted zones, and AWS Global Accelerator.

How AWS WAF Works

AWS WAF lets you control the way AWS products respond to HTTP requests, including Amazon CloudFront distributions, Amazon API Gateway APIs, application load balancers, and AWS AppSync GraphQL APIs.

Web ACLs

A web access control list helps protect a group of AWS resources. You add rules to define your defense strategy when you create web ACLs—these rules define how AWS inspects web requests. You can set default actions to indicate if the ACL should allow or block requests based on the inspection rules.

The criteria for allowing or blocking a request may include its origin IP, origin country, identified malicious scripts, regular expressions, or request size. You can also block requests exceeding a limit within five-minute periods.

Rules

Each rule group and web ACL uses rules to define web request inspection and responses. Rules must have top-level statements—sometimes containing nested statements. The rules are in JSON format and provide inspection instructions.

Web ACL rules for managing HTTP requests may use various criteria such as suspicious scripts, malicious IP addresses and address ranges, geographical origins, length of query strings, suspicious SQL code, and more. These rules can help prevent various attacks, including cross-site scripting and SQL injection. You can also reuse labels from existing web ACL rules.

Rule Groups

A rule group is a collection of rules that web ACLs can reuse. You can use AWS-managed, third-party managed, or custom rule groups that you maintain. Both web ACLs and rule groups contain rules defined in the same way. However, a rule group differs from a web ACL because it lacks reference statements and is reusable in different ACLs (web ACLs are not reusable).

Rule groups also lack default actions—you have to define actions for each rule. Another difference from web ACLs is that you don't associate rule groups directly with AWS resources—you have to use a rule group within an ACL to protect a resource.

3 AWS WAF Best Practices

Here are some of the best practices to help you make the most of AWS WAF:

Test Before Deploying to Production

Once you've tested the WAF implementation and verified it works in the staging environment, you can determine when to deploy it to the production environment. Choose the date and time you expect to have the least user traffic. The security and application development teams should evaluate your operational readiness before deploying the implementation. Consider rollback procedures and ensure the dashboards have properly configured metrics and alerts.

Create an incident response runbook to explain how your teams can perform rollbacks and additional mitigation tasks. Ensure every team member knows how to respond to security threats, including implementing configuration updates, deploying in different accounts, troubleshooting problems, and remediating threats. The runbook should outline all the steps your teams should take.

Deploy AWS WAF Using Count Mode

Count mode is an option in AWS WAF that reports the number of web requests that would be blocked by your rules, but does not actually block them. This is a good way to understand the production impact of your rules before turning them on.

Once you've established operational readiness, you can deploy AWS WAF for the production endpoints you want to protect. Choose which rules you want to trial first and use count mode to identify false positives in the production environment that might not have appeared in the staging environment. This approach helps you ensure legitimate traffic flows smoothly, especially when deploying WAF rules for the first time.

Note that the application may be vulnerable to an attack that the rule in count mode would otherwise block. You only ensure real protection when you push the rule block mode. If you are confident in the rule's efficacy and don't expect many false positives, you might not want to trial rules in production.

When using count mode, review your dashboards and metrics to verify that rules match their intended purpose. Once you see the rules operated correctly, switch them to block mode.

Conduct Post Deployment Evaluations

Periodically monitor and review the application after you deploy AWS WAF. At this stage, security and development teams should regularly review dashboards to establish a baseline of normal application traffic. You can leverage AWS WAF logs alongside tools like Athena, OpenSearch Service, and external SIEM solutions to analyze traffic patterns and identify potentially threatening changes.

These tools provide detailed information to help you understand anomalies, detect new threats, or recognize false alarms. Review your runbook to keep it up to date. Practice the runbook regularly to see how well it performs and let team members familiarize themselves with security response procedures.

Regular penetration testing is another useful way to keep up with emerging threats and address zero-day vulnerabilities. Keep your WAF rules current to ensure they protect your application against the latest threats. Using managed rules will help you reduce the technical effort required to keep your WAF up to date. AWS and third-party WAF providers regularly update managed rules—however, you should also proactively upgrade your custom or application-specific WAF rules.

Conclusion

In this article, we discussed the basics of AWS WAF, a managed web application firewall in the Amazon cloud.

We also introduced two related Amazon services - AWS Firewall Manager, which can help you manage WAF configurations across a large number of resources and multiple Amazon accounts, and AWS Shield, which leverages WAF ACLs to protect against DDoS attacks.

Finally, we provided three best practices you can use to make more effective use of AWS WAF:

- **Test before deploying to production** - test WAF rules in a staging environment, and deploy to production during an off period to ensure rules are working properly.
- **Use count mode** - initially deploy WAF to production using “count mode”, which reports the number of web requests that would be blocked by your rules, without actually blocking them yet.
- **Conduct post deployment evaluations** - even after turning on your rules, periodically evaluate WAF to see if it is blocking legitimate traffic and adjust rules accordingly.

HackerOne can help you identify application vulnerabilities and smartly define WAF rules. [Learn more about HackerOne security assessments.](#)

Company

Knowledge

Resources

Leadership

Center

Blog

Careers

Application Security

Documentation

Partners

Penetration Testing

Leaderboard

Newsroom

Cloud Security

Partner Portal

Contact Us

Hacking

Resources

Cybersecurity

Attacks

DevSecOps

Contacted
by a  hacker?

Trust